



CyberScan
Security Audit Platform

RAPPORT D'AUDIT DE SÉCURITÉ

CyberScan — Plateforme d'analyse automatisée

Domaine : google.com

Date : 17/07/2026 16:16

CRITIQUE

Sécurité 1.4/10 — Risque IA 8.6000000000000001/10

Document confidentiel — Usage interne uniquement

Sommaire

1. Informations générales
2. Résumé exécutif
3. Outils utilisés
4. Résultats du scan
5. Technologies détectées
6. Vulnérabilités
7. CVE et scores CVSS
8. Recommandations IA
9. Plan de correction
10. Conclusion

Rapport d'audit de sécurité

CyberScan — Analyse automatisée multi-outils

■ Informations générales

Domaine analysé	google.com
Date du scan	17/07/2026 16:16
Score global de sécurité	1.4/10
Score de risque IA	8.600000000000001/10
Niveau de risque	Critique
Identifiant scan	57

NIVEAU DE RISQUE : CRITIQUE | Sécurité 1.4/10 | Risque IA 8.600000000000001/10

■ Résumé exécutif

Ce rapport présente les résultats de l'audit de sécurité automatisé réalisé par CyberScan sur le domaine « google.com » le 17/07/2026 à 16:16 (UTC). Le score global de sécurité est estimé à 1.4/10, correspondant à un niveau de risque « Critique » (score de risque IA : 8.600000000000001/10). Synthèse : 42 CVE référencée(s), 3 indicateur(s) SSL/TLS, 4 protocole(s) détecté(s), 12 technologie(s) web, 16 alerte(s) OWASP ZAP, 40 résultat(s) NVD. Des vulnérabilités critiques ou un score de risque élevé nécessitent une remédiation prioritaire. Consultez les sections CVE et Recommandations.

■ Outils utilisés

- SSLScan
- OpenSSL
- Nmap
- WhatWeb
- OWASP ZAP Baseline
- NVD API

■ Résultats du scan — synthèse

Les sections suivantes détaillent les sorties brutes de chaque outil exécuté lors de l'audit automatisé.

■ Technologies détectées

```
• Country (UNITED STATES)
• HTTPServer (gws)
• IP (142.251.141.238, 142.251.153.119)
• RedirectLocation (https://www.google.com/)
• Title (301 Moved, Google)
• UncommonHeaders (content-security-policy-report-only,alt-svc,
```

```
content-security-policy-report-only,accept-ch,alt-svc)
• X-Frame-Options (SAMEORIGIN)
• X-XSS-Protection (0)
• Cookies (AEC, NID, __Secure-STRP)
• HTML5
• HttpOnly (AEC, NID)
• Script
```

■ Vulnérabilités

```
• WEAK_CIPHER (SSL/TLS)
• TLSv1.1 (SSL/TLS)
• TLSv1.0 (SSL/TLS)
• [Medium] Content Security Policy (CSP) Header Not Set – https://google.com
• [Medium] Sub Resource Integrity Attribute Missing – https://google.com
• [Low] Cookie No HttpOnly Flag – https://google.com
• [Low] Cookie with SameSite Attribute None – https://google.com
• [Low] Cross-Domain JavaScript Source File Inclusion – https://google.com
• [Low] Cross-Origin-Embedder-Policy Header Missing or Invalid – https://google.com
• [Low] Cross-Origin-Opener-Policy Header Missing or Invalid – https://google.com
• [Low] Cross-Origin-Resource-Policy Header Missing or Invalid – https://google.com
• [Low] Strict-Transport-Security Header Not Set – https://google.com
• [Low] X-Content-Type-Options Header Missing – https://google.com
• [Informational] Content Security Policy (CSP) Report-Only Header Found – https://google.com
• [Informational] Non-Storable Content – https://google.com
• [Informational] Re-examine Cache-control Directives – https://google.com
• [Informational] Retrieved from Cache – https://google.com/robots.txt
• [Informational] Session Management Response Identified – https://google.com
• [Informational] Storable and Cacheable Content – https://google.com
```

■ Résultats SSLScan

Protocoles : TLSv1.0, TLSv1.1, TLSv1.2, TLSv1.3. Vulnérabilités SSL : WEAK_CIPHER, TLSv1.1, TLSv1.0.

```
Version: ■[32m2.1.5■[0m
OpenSSL 3.5.6 7 Apr 2026
■[0m
■[32mConnected to 142.251.141.238■[0m

Testing SSL server ■[32mgoogle.com■[0m on port ■[32m443■[0m using SNI name ■[32mgoogle.com■[0m

■[1;34mSSL/TLS Protocols:■[0m
SSLv2 ■[32mdisabled■[0m
SSLv3 ■[32mdisabled■[0m
TLSv1.0 ■[33menabled■[0m
TLSv1.1 ■[33menabled■[0m
TLSv1.2 enabled
TLSv1.3 ■[32menabled■[0m

■[1;34mTLS Fallback SCSV:■[0m
Server ■[32msupports■[0m TLS Fallback SCSV

■[1;34mTLS renegotiation:■[0m
■[32mSecure■[0m session renegotiation supported

■[1;34mTLS Compression:■[0m
Compression ■[32mdisabled■[0m

■[1;34mHeartbleed:■[0m
TLSv1.3 ■[32mnot vulnerable■[0m to heartbleed
TLSv1.2 ■[32mnot vulnerable■[0m to heartbleed
TLSv1.1 ■[32mnot vulnerable■[0m to heartbleed
TLSv1.0 ■[32mnot vulnerable■[0m to heartbleed

■[1;34mSupported Server Cipher(s):■[0m
■[32mPreferred■[0m ■[32mTLSv1.3■[0m ■[32m128■[0m bits ■[32mTLS_AES_128_GCM_SHA256 ■[0m
Accepted ■[32mTLSv1.3■[0m ■[32m256■[0m bits ■[32mTLS_AES_256_GCM_SHA384 ■[0m
Accepted ■[32mTLSv1.3■[0m ■[32m256■[0m bits ■[32mTLS_CHACHA20_POLY1305_SHA256 ■[0m
■[32mPreferred■[0m TLSv1.2 ■[32m256■[0m bits ■[32mECDHE-ECDSA-CHACHA20-POLY1305■[0m Curve ■[32m25519■[0m
DHE 253
Accepted TLSv1.2 ■[32m128■[0m bits ■[32mECDHE-ECDSA-AES128-GCM-SHA256■[0m Curve ■[32m25519■[0m DHE 253
Accepted TLSv1.2 ■[32m256■[0m bits ■[32mECDHE-ECDSA-AES256-GCM-SHA384■[0m Curve ■[32m25519■[0m DHE 253
Accepted TLSv1.2 ■[32m128■[0m bits ECDHE-ECDSA-AES128-SHA Curve ■[32m25519■[0m DHE 253
```

```

Accepted TLSv1.2 ■[32m256■[0m bits ECDHE-ECDSA-AES256-SHA Curve ■[32m25519■[0m DHE 253
Accepted TLSv1.2 ■[32m256■[0m bits ■[32mECDHE-RSA-CHACHA20-POLY1305 ■[0m Curve ■[32m25519■[0m DHE 253

Accepted TLSv1.2 ■[32m128■[0m bits ■[32mECDHE-RSA-AES128-GCM-SHA256 ■[0m Curve ■[32m25519■[0m DHE 253
Accepted TLSv1.2 ■[32m256■[0m bits ■[32mECDHE-RSA-AES256-GCM-SHA384 ■[0m Curve ■[32m25519■[0m DHE 253
Accepted TLSv1.2 ■[32m128■[0m bits ECDHE-RSA-AES128-SHA Curve ■[32m25519■[0m DHE 253
Accepted TLSv1.2 ■[32m256■[0m bits ECDHE-RSA-AES256-SHA Curve ■[32m25519■[0m DHE 253
Accepted TLSv1.2 ■[32m128■[0m bits AES128-GCM-SHA256
Accepted TLSv1.2 ■[32m256■[0m bits AES256-GCM-SHA384
Accepted TLSv1.2 ■[32m128■[0m bits AES128-SHA
Accepted TLSv1.2 ■[32m256■[0m bits AES256-SHA
Accepted TLSv1.2 ■[32m112■[0m bits ■[33mTLS_RSA_WITH_3DES_EDE_CBC_SHA■[0m
■[32mPreferred■[0m ■[33mTLSv1.1■[0m ■[32m128■[0m bits ECDHE-ECDSA-AES128-SHA Curve ■[32m25519■[0m DHE 253
Accepted ■[33mTLSv1.1■[0m ■[32m256■[0m bits ECDHE-ECDSA-AES256-SHA Curve ■[32m25519■[0m DHE 253
Accepted ■[33mTLSv1.1■[0m ■[32m128■[0m bits ECDHE-RSA-AES128-SHA Curve ■[32m25519■[0m DHE 253
Accepted ■[33mTLSv1.1■[0m ■[32m256■[0m bits ECDHE-RSA-AES256-SHA Curve ■[32m25519■[0m DHE 253
Accepted ■[33mTLSv1.1■[0m ■[32m128■[0m bits AES128-SHA
Accepted ■[33mTLSv1.1■[0m ■[32m256■[0m bits AES256-SHA
Accepted ■[33mTLSv1.1■[0m ■[32m112■[0m bits ■[33mTLS_RSA_WITH_3DES_EDE_CBC_SHA■[0m
■[32mPreferred■[0m ■[33mTLSv1.0■[0m ■[32m128■[0m bits ECDHE-ECDSA-AES128-SHA Curve ■[32m25519■[0m DHE 253
Accepted ■[33mTLSv1.0■[0m ■[32m256■[0m bits ECDHE-ECDSA-AES256-SHA Curve ■[32m25519■[0m DHE 253
Accepted ■[33mTLSv1.0■[0m ■[32m128■[0m bits ECDHE-RSA-AES128-SHA Curve ■[32m25519■[0m DHE 253
Accep

[... sortie tronquée pour lisibilité du rapport ...]

```

■ Résultats OpenSSL

```

Connecting to 142.251.141.238
depth=2 C=US, O=Google Trust Services LLC, CN=GTS Root R1
verify return:1
depth=1 C=US, O=Google Trust Services, CN=WR2
verify return:1
depth=0 CN=*.google.com
verify return:1
CONNECTED(00000003)
---
Certificate chain
0 s:CN=*.google.com
i:C=US, O=Google Trust Services, CN=WR2
a:PKEY: EC, (prime256v1); sigalg: sha256WithRSAEncryption
v:NotBefore: Jun 29 08:37:25 2026 GMT; NotAfter: Sep 21 08:37:24 2026 GMT
1 s:C=US, O=Google Trust Services, CN=WR2
i:C=US, O=Google Trust Services LLC, CN=GTS Root R1
a:PKEY: RSA, 2048 (bit); sigalg: sha256WithRSAEncryption
v:NotBefore: Dec 13 09:00:00 2023 GMT; NotAfter: Feb 20 14:00:00 2029 GMT
2 s:C=US, O=Google Trust Services LLC, CN=GTS Root R1
i:C=BE, O=GlobalSign nv-sa, OU=Root CA, CN=GlobalSign Root CA
a:PKEY: RSA, 4096 (bit); sigalg: sha256WithRSAEncryption
v:NotBefore: Jun 19 00:00:42 2020 GMT; NotAfter: Jan 28 00:00:42 2028 GMT
---
Server certificate
-----BEGIN CERTIFICATE-----
MIIIIdTCCB12gAwIBAgIQArDBmbXy/5YJXjyGGvQr7jANBgkqhkiG9w0BAQsFADA7
MQswCQYDVQQGEwJVUzEeMBwGA1UEChMVR29vZ2xlIFRydXN0IFNlcnpY2VzMQww
CgYDVQQDEwNXUjIwHhcNMjYwNjI1MDgzNzI1WWhcNMjYwOTIxMDgzNzI0WjAXMRUw
EwYDVQQDDAwqLmdvb2dsZS5jb20wWTATBgqhkiG9w0BAQsFADBBBgqhkiG9w0BAQsF
H70i8enSTNrvh0rvehNSVZxc8L6h1wUYazISj4TKa+PT5i4Ta0r+FmN3jWEvf/s
nMTzB+VjraqhfWQAHO8fo4IGYjCCBL4wDgYDVR0PAAQh/BAQDAgeAMBGA1UdJQQM
MAoGCCsGAQUFBwMBMAwGA1UdEwEB/wQCMAAwHQYDVR0OBBYEFJUXUMxwSpWcIFwL
liPY18slkvAHMB8GA1UdIwQYMBaAFN4bHu15FdQ+NyTDIbvsNDltQrIwMfGgCCsG
AQUFBwEBBEwwSjAhBggrBgEFBQcwAYYVaHR0cDovL28ucGtpLmdvb2cvd2IyMCUG
CCsGAQUFBzACHhloDRW0i8vaS5wa2kuZ29vZy93cjIuY3J0MIIEOAYDVR0RBIIE
LzCCBCuCDCouZ29vZ2xlLmNvbYIWKi5hcHBmbmdpbmUuZ29vZ2xlLmNvbYIJKi5i
ZG4uZGV2ghUqLm9yaWdpbi10ZXN0LmJkbj5kZXACEiouY2xvdWQuZ29vZ2xlLmNv
bYIYKi5jcm93ZHNvdXJjZS5nb29nbGUuY29tghgqLmRhdfGFjb21wdXRlLmdvb2ds
ZS5jb22CCyouZ29vZ2xlLmNhggsgLmdvb2dsZS5jb2I0Ki5nb29nbGUuY28uaW6C
DiouZ29vZ2xlLmNvLmpwgg4qLmdvb2dsZS5jb251a4IPKi5nb29nbGUuY29tLmFy

gg8qLmdvb2dsZS5jb20uYXwCyouZ29vZ2xlLmNvbS5icoIPKi5nb29nbGUuY29t
LmNvgg8qLmdvb2dsZS5jb20ubXiCDyouZ29vZ2xlLmNvbS50coIPKi5nb29nbGUu
Y29tLnZuggsgLmdvb2dsZS5kZYLKl5nb29nbGUuZXOCCyouZ29vZ2xlLmZyggsg
Lmdvb2dsZS5odYILKi5nb29nbGUuXSCCyouZ29vZ2xlLm5sgsgLmdvb2dsZS5w

```

bIILKi5nb29nbGUuchSCGSouZ2VtaW5pLmNsb3VkLmdvb2dsZS5jb22CDSouZ3N0
YXRpYy5jb22CFcoubW0cm1jLmdzdGF0awMuY29tggoqLmd2dDEuY29tghEqLmdj
cGNkbi5ndnQxLmNvbYIKKi5ndnQyLmNvbYIOKi5nY3AuZ3Z0Mi5jb22CECoudXJs
Lmdvb2dsZS5jb22CFiouew91dHVizS1ub2Nvb2tpZS5jb22CCyoeXRpbWcuY29t
ggphaS5hbmRyb2lkkggthbmRyb2lkLmNvbYINKi5hbmRyb2lkLmNvbYITKi5mbGFz
aC5hbmRyb2lkLmNvbYIEZy5jb4IGKi5nLmNvggZnb28uZ2yCCnd3dy5nb28uZ2yC
FGdvb2dsZS1hbmFseXRpY3MuY29tghYqLmdvb2dsZS1hbmFseXRpY3MuY29tggn
b29nbGUuY29tghJnb29nbGVjb21tZXJjZS5jb22CFCouZ29vZ2xly29tbWVyY2Uu
Y29tggn1cmNoaw4uY29tggnwLmVvY2hpb25jb22CCHlvdXR1LmJlggt5b3V0dWJl
LmNvbYINKi55b3V0dWJlLmNvbYIRbXVzawMuew91dHVizS5jb22CEyoubXVzawMu
eW91dHVizS5jb22CFHlvdXR1YmVlZHVjYXRpb24uY29tghYqLnlvdXR1YmVlZHVj
YXRpb24uY29tggn95b3V0dWJla2lkcy5jb22CESoueW91dHVizWtpZHMuY29tggnV5
dC5iZyIHKi55dC5iZyIaYw5kcm9pZC5jbGllbnRzLmdvb2dsZS5jb22CFSouYwLz
dHVkaW8uZ29vZ2x1LmNvbYATBgNVHSAEDDAKMAgGBmeBDAECATA2BgNVHR8ELzAt
MCugKaAnhiVodHRwOi8vYy5wa2kuZ29vZy93cjIvNzVyNfp5QTN2QTauY3JsmIIB
BAYKKwYBBAHweQIEAgSB9QSB8gDwAHYA1219ENGn9XfCx+lf1wC/+YLJM1pl4dCz
AXMXwMjFaXcAAAGfer2uawAABAMARzBFAiEAhQiz0f3I8Hl0F8WiEgyY6tU1objr
W0sat1EWBbabND4CIgdpZ4Cia9/39dTrAD8YrYibY3WQiZrruEiagMRwzHZAUAHYA
yzj3FYl8hKFEX1vB3fvJbvKaWc1HCmkFhbDLFMMUW0cAAAGfer2ulgAABAMARzBF
AiA59eNHYQ+sQFGIVkhsLWG1mN0jLUCPh7REa

[... sortie tronquée pour lisibilité du rapport ...]

■ Résultats Nmap

Starting Nmap 7.95 (<https://nmap.org>) at 2026-07-17 17:03 CET
Nmap scan report for google.com (142.251.141.238)
Host is up (0.063s latency).
Other addresses for google.com (not scanned): 2a00:1450:4002:401::200e
rDNS record for 142.251.141.238: tzmila-ac-in-f14.1e100.net

PORT STATE SERVICE

443/tcp open https

| ssl-enum-ciphers:

| TLSv1.0:

| ciphers:

| TLS_ECDHE_ECDSA_WITH_AES_128_CBC_SHA (ecdh_x25519) - A

| TLS_ECDHE_ECDSA_WITH_AES_256_CBC_SHA (ecdh_x25519) - A

| TLS_ECDHE_RSA_WITH_AES_128_CBC_SHA (ecdh_x25519) - A

| TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA (ecdh_x25519) - A

| TLS_RSA_WITH_AES_128_CBC_SHA (rsa 2048) - A

| TLS_RSA_WITH_AES_256_CBC_SHA (rsa 2048) - A

| TLS_RSA_WITH_3DES_EDE_CBC_SHA (rsa 2048) - C

| compressors:

| NULL

| cipher preference: server

| warnings:

| 64-bit block cipher 3DES vulnerable to SWEET32 attack

| TLSv1.1:

| ciphers:

| TLS_ECDHE_ECDSA_WITH_AES_128_CBC_SHA (ecdh_x25519) - A

| TLS_ECDHE_ECDSA_WITH_AES_256_CBC_SHA (ecdh_x25519) - A

| TLS_ECDHE_RSA_WITH_AES_128_CBC_SHA (ecdh_x25519) - A

| TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA (ecdh_x25519) - A

| TLS_RSA_WITH_AES_128_CBC_SHA (rsa 2048) - A

| TLS_RSA_WITH_AES_256_CBC_SHA (rsa 2048) - A

| TLS_RSA_WITH_3DES_EDE_CBC_SHA (rsa 2048) - C

| compressors:

| NULL

| cipher preference: server

| warnings:

| 64-bit block cipher 3DES vulnerable to SWEET32 attack

| TLSv1.2:

| ciphers:

| TLS_ECDHE_ECDSA_WITH_AES_128_CBC_SHA (ecdh_x25519) - A

| TLS_ECDHE_ECDSA_WITH_AES_128_GCM_SHA256 (ecdh_x25519) - A

| TLS_ECDHE_ECDSA_WITH_AES_256_CBC_SHA (ecdh_x25519) - A

| TLS_ECDHE_ECDSA_WITH_AES_256_GCM_SHA384 (ecdh_x25519) - A

| TLS_ECDHE_ECDSA_WITH_CHACHA20_POLY1305_SHA256 (ecdh_x25519) - A

| TLS_ECDHE_RSA_WITH_AES_128_CBC_SHA (ecdh_x25519) - A

| TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256 (ecdh_x25519) - A

| TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA (ecdh_x25519) - A

```
| TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384 (ecdhe_x25519) - A
| TLS_ECDHE_RSA_WITH_CHACHA20_POLY1305_SHA256 (ecdhe_x25519) - A
| TLS_RSA_WITH_3DES_EDE_CBC_SHA (rsa 2048) - C
| TLS_RSA_WITH_AES_128_CBC_SHA (rsa 2048) - A
| TLS_RSA_WITH_AES_128_GCM_SHA256 (rsa 2048) - A
| TLS_RSA_WITH_AES_256_CBC_SHA (rsa 2048) - A
| TLS_RSA_WITH_AES_256_GCM_SHA384 (rsa 2048) - A
| compressors:
| NULL
| cipher preference: client
| warnings:
| 64-bit block cipher 3DES vulnerable to SWEET32 attack
| TLSv1.3:
| ciphers:
| TLS_AKE_WITH_AES_128_GCM_SHA256 (ecdhe_x25519) - A
| TLS_AKE_WITH_AES_256_GCM_SHA384 (ecdhe_x25519) - A
| TLS_AKE_WITH_CHACHA20_POLY1305_SHA256 (ecdhe_x25519) - A
| cipher preference: client
|_ least strength: C
```

Nmap done: 1 IP address (1 host up) scanned in 5.68 seconds

■ Résultats WhatWeb

- Country (UNITED STATES)
- HTTPServer (gws)
- IP (142.251.141.238, 142.251.153.119)
- RedirectLocation (https://www.google.com/)
- Title (301 Moved, Google)
- UncommonHeaders (content-security-policy-report-only,alt-svc, content-security-policy-report-only,accept-ch,alt-svc)
- X-Frame-Options (SAMEORIGIN)
- X-XSS-Protection (0)
- Cookies (AEC, NID, __Secure-STRP)
- HTML5
- HttpOnly (AEC, NID)
- Script

■ Résultats OWASP ZAP

- [Medium] Content Security Policy (CSP) Header Not Set – https://google.com (×1)
Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks, including Cross Site Scripting (XSS) and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a
- [Medium] Sub Resource Integrity Attribute Missing – https://google.com (×2)
The integrity attribute is missing on a script or link tag served by an external server. The integrity tag prevents an attacker who have gained access to this server from injecting a malicious content.
- [Low] Cookie No HttpOnly Flag – https://google.com (×1)
A cookie has been set without the HttpOnly flag, which means that the cookie can be accessed by JavaScript. If a malicious script can be run on this page then the cookie will be accessible and can be transmitted to another site. If this is a session cookie then session hijacking may be possible.
- [Low] Cookie with SameSite Attribute None – https://google.com (×1)
A cookie has been set with its SameSite attribute set to "none", which means that the cookie can be sent as a result of a 'cross-site' request. The SameSite attribute is an effective counter measure to cross-site request forgery, cross-site script inclusion, and timing attacks.
- [Low] Cross-Domain JavaScript Source File Inclusion – https://google.com (×1)
The page includes one or more script files from a third-party domain.
- [Low] Cross-Origin-Embedder-Policy Header Missing or Invalid – https://google.com (×1)
Cross-Origin-Embedder-Policy header is a response header that prevents a document from loading any cross-origin resources that don't explicitly grant the document permission (using CORP or CORS).
- [Low] Cross-Origin-Opener-Policy Header Missing or Invalid – https://google.com (×1)
Cross-Origin-Opener-Policy header is a response header that allows a site to control if others included documents share the same browsing context. Sharing the same browsing context with untrusted documents might lead to data leak.
- [Low] Cross-Origin-Resource-Policy Header Missing or Invalid – https://google.com (×1)
Cross-Origin-Resource-Policy header is an opt-in header designed to counter side-channels attacks like Spectre. Resource should be specifically set as shareable amongst different origins.
- [Low] Strict-Transport-Security Header Not Set – https://google.com (×3)
HTTP Strict Transport Security (HSTS) is a web security policy mechanism whereby a web server declares that complying user agents (such as a web browser) are to interact with it using only secure HTTPS connections (i.e. HTTP layered over TLS/SSL). HSTS is an IETF standards track protocol and is spec
- [Low] X-Content-Type-Options Header Missing – https://google.com (×1)

The Anti-MIME-Sniffing header X-Content-Type-Options was not set to 'nosniff'. This allows older versions of Internet Explorer and Chrome to perform MIME-sniffing on the response body, potentially causing the response body to be interpreted and displayed as a content type other than the declared con

- [Informational] Content Security Policy (CSP) Report-Only Header Found – <https://google.com> (x1)

The response contained a Content-Security-Policy-Report-Only header, this may indicate a work-in-progress implementation, or an oversight in promoting pre-Prod to Prod, etc. Content Security Policy (CSP) is an added layer of security

[... sortie tronquée pour lisibilité du rapport ...]

■ Résultats SSL Labs API

SSL Labs non inclus dans ce scan. Les résultats SSL Labs apparaîtront ici lorsqu'ils seront présents dans `resultats_ssl["ssllabs"]`.

■ Résultats NVD API

Statut NVD : Erreur

Nombre de CVE NVD : 40

Erreurs : Limite NVD publique atteinte; configurez NVD_API_KEY pour rechercher les autres technologies.

- CVE-2003-1268 – CVSS 7.5 (HIGH) – Multiple SQL injection vulnerabilities in (1) addcustomer.asp, (2) addprod.asp, and (3) process.asp in a.shopKart 2.0.3 allow remote attackers to execute arbitrary SQL and obtain sensitive information
- CVE-2004-1926 – CVSS 7.5 (HIGH) – Tiki CMS/Groupware (TikiWiki) 1.8.1 and earlier allows remote attackers to inject arbitrary code via the (1) Theme, (2) Country, (3) Real Name, or (4) Displayed time zone fields in a User Profile, or
- CVE-2004-0866 – CVSS 7.5 (HIGH) – Internet Explorer 6.0 allows web sites to set cookies for country-specific top-level domains, such as .ltd.uk, .plc.uk, and .sch.uk, which could allow remote attackers to perform a session fixation at
- CVE-2004-0746 – CVSS 7.5 (HIGH) – Konqueror in KDE 3.2.3 and earlier allows web sites to set cookies for country-specific top-level domains, such as .ltd.uk, .plc.uk and .firm.in, which could allow remote attackers to perform a sessio
- CVE-2004-0867 – CVSS 7.5 (HIGH) – Mozilla Firefox 0.9.2 allows web sites to set cookies for country-specific top-level domains, such as .ltd.uk, .plc.uk, and .sch.uk, which could allow remote attackers to perform a session fixation at
- CVE-2004-2180 – CVSS 4.3 (MEDIUM) – Multiple cross-site scripting (XSS) vulnerabilities in WowBB Forum 1.61 allow remote attackers to inject arbitrary web script or HTML via the (1) country parameter to view_user.php, (2) show parameter
- CVE-2004-2511 – CVSS 4.3 (MEDIUM) – Multiple cross-site scripting (XSS) vulnerabilities in DCP-Portal 5.3.2 and earlier allow remote attackers to inject arbitrary web script or HTML via (1) the year, (2) month, and (3) day parameters in
- CVE-2005-0995 – CVSS 4.3 (MEDIUM) – Multiple cross-site scripting (XSS) vulnerabilities in ProductCart 2.7 allow remote attackers to inject arbitrary web script or HTML via (1) the keyword parameter to advSearch_h.asp, (2) the redirectU
- CVE-2005-2985 – CVSS 7.5 (HIGH) – SQL injection vulnerability in search_result.php in AEwebworks aeDating Script 4.0 and earlier allows remote attackers to execute arbitrary SQL statements via the Country parameter.
- CVE-2005-4576 – CVSS 4.3 (MEDIUM) – Multiple cross-site scripting (XSS) vulnerabilities in the UpdateEngine program in Fatwire UpdateEngine 6.2 and earlier allow remote attackers to inject arbitrary web script or HTML via the (1) COUNTR
- CVE-2007-1939 – CVSS 6.8 (MEDIUM) – Cross-site scripting (XSS) vulnerability in the embedded webserver in Daniel Naber LanguageTool before 0.8.9 allows remote attackers to inject arbitrary web script or HTML via unspecified vectors invo
- CVE-2017-7504 – CVSS 9.8 (CRITICAL) – HTTPServerILServlet.java in JMS over HTTP Invocation Layer of the JbossMQ implementation, which is enabled by default in Red Hat Jboss Application Server <= Jboss 4.X does not restrict the classes for
- CVE-2018-12537 – CVSS 5.3 (MEDIUM) – In Eclipse Vert.x version 3.0 to 3.5.1, the HttpServer response headers and HttpClient request headers do not filter carriage return and line feed characters from the header value. This allow unfilter
- CVE-2019-3888 – CVSS 9.8 (CRITICAL) – A vulnerability was found in Undertow web server before 2.0.21. An information exposure of plain text credentials through log files because Connectors.executeRootHandler:402 logs the HttpServerExchang
- CVE-2020-5403 – CVSS 7.5 (HIGH)

[... sortie tronquée pour lisibilité du rapport ...]

■ Liste des CVE et scores CVSS

--	--	--

CVE-2014-3566	7.5	Protocole TLSv1.0 obsolète détecté, vulnérable aux attaques POODLE.
CVE-2016-2183	7.5	Suites de chiffrement 3DES/RC4 faibles détectées, vulnérables à l'attaque Sweet32.
CVE-2003-1268	7.5	Multiple SQL injection vulnerabilities in (1) addcustomer.asp, (2) addprod.asp, and (3) process.asp in a.shopKart 2.0.3 allow remote attackers to execute arbitrary SQL and obtain sensitive information via the zip, state, country, phone, and fax parameters.
CVE-2004-1926	7.5	Tiki CMS/Groupware (TikiWiki) 1.8.1 and earlier allows remote attackers to inject arbitrary code via the (1) Theme, (2) Country, (3) Real Name, or (4) Displayed time zone fields in a User Profile, or the (5) Name, (6) Description, (7) URL, or (8) Country fields in a Directory/Add Site operation.
CVE-2004-0866	7.5	Internet Explorer 6.0 allows web sites to set cookies for country-specific top-level domains, such as .ltd.uk, .plc.uk, and .sch.uk, which could allow remote attackers to perform a session fixation attack and hijack a user's HTTP session.
CVE-2004-0746	7.5	Konqueror in KDE 3.2.3 and earlier allows web sites to set cookies for country-specific top-level domains, such as .ltd.uk, .plc.uk and .firm.in, which could allow remote attackers to perform a session fixation attack and hijack a user's HTTP session.
CVE-2004-0867	7.5	Mozilla Firefox 0.9.2 allows web sites to set cookies for country-specific top-level domains, such as .ltd.uk, .plc.uk, and .sch.uk, which could allow remote attackers to perform a session fixation attack and hijack a user's HTTP session. NOTE: it was later reported that 2.x is also affected.
CVE-2004-2180	4.3	Multiple cross-site scripting (XSS) vulnerabilities in WowBB Forum 1.61 allow remote attackers to inject arbitrary web script or HTML via the (1) country parameter to view_user.php, (2) show parameter to view_forum.php, (3) letter parameter to view_user.php, (4) highlight parameter to view_topic.php, (5) show parameter to index.php, (6) q parameter to search.php, (7) Referer header to admin.php, or
CVE-2004-2511	4.3	Multiple cross-site scripting (XSS) vulnerabilities in DCP-Portal 5.3.2 and earlier allow remote attackers to inject arbitrary web script or HTML via (1) the year, (2) month, and (3) day parameters in calendar.php; (4) the cid and (5) url parameters in index.php; (6) the cid parameter in announcement.php; (7) the cid parameter in news.php; (8) the cid parameter in contents.php; (9) the q parameter
CVE-2005-0995	4.3	Multiple cross-site scripting (XSS) vulnerabilities in ProductCart 2.7 allow remote attackers to inject arbitrary web script or HTML via (1) the keyword parameter to advSearch_h.asp, (2) the redirectUrl parameter to NewCust.asp, (3) the country parameter to storelocator_submit.asp, or (4) the error parameter to techErr.asp. NOTE: it has been reported that storelocator_submit.asp does not exist in
CVE-2005-2985	7.5	SQL injection vulnerability in search_result.php in AEwebworks aeDating Script 4.0 and earlier allows remote attackers to execute arbitrary SQL statements via the Country parameter.
CVE-2005-4576	4.3	Multiple cross-site scripting (XSS) vulnerabilities in the UpdateEngine program in Fatwire UpdateEngine 6.2 and earlier allow remote attackers to inject arbitrary web script or HTML via the (1) COUNTRYNAME, (2) EMAIL, and (3) FUELAP_TEMPLATENAME parameters.
CVE-2007-1939	6.8	Cross-site scripting (XSS) vulnerability in the embedded webserver in Daniel Naber LanguageTool before 0.8.9 allows remote attackers to inject arbitrary web script or HTML via unspecified vectors involving an error message, possibly the demultiplex method in HTTPServer.java.
CVE-2017-7504	9.8	HTTPServerILServlet.java in JMS over HTTP Invocation Layer of the JbossMQ implementation, which is enabled by default in Red Hat Jboss Application Server <= Jboss 4.X does not restrict the classes for which it performs deserialization, which allows remote attackers to execute arbitrary code via crafted serialized data.
CVE-2018-12537	5.3	In Eclipse Vert.x version 3.0 to 3.5.1, the HttpServer response headers and HttpClient request headers do not filter carriage return and line feed characters from the header value. This allow unfiltered values to inject a new header in the client request or server response.

CVE-2019-3888	9.8	A vulnerability was found in Undertow web server before 2.0.21. An information exposure of plain text credentials through log files because Connectors.executeRootHandler:402 logs the HttpServerExchange object at ERROR level using UndertowLogger.REQUEST_LOGGER.undertowRequestFailed(t, exchange)
CVE-2020-5403	7.5	Reactor Netty HttpServer, versions 0.9.3 and 0.9.4, is exposed to a URISyntaxException that causes the connection to be closed prematurely instead of producing a 400 response.
CVE-2022-35252	3.7	When curl is used to retrieve and parse cookies from a HTTP(S) server, it accepts cookies using control codes that when later are sent back to a HTTPserver might make the server return 400 responses. Effectively allowing a "sister site" to deny service to all siblings.
CVE-2019-25087	5.3	A vulnerability was found in RamseyK httpserver. It has been rated as critical. This issue affects the function ResourceHost::getResource of the file src/ResourceHost.cpp of the component URI Handler. The manipulation of the argument uri leads to path traversal: '../filedir'. The attack may be initiated remotely. The name of the patch is 1a0de56e4daff9c2f9c8f6b130a764f7a50df52. It is recommended
CVE-2026-35392	9.8	goshs is a SimpleHTTPServer written in Go. Prior to 2.0.0-beta.3, PUT upload in httpserver/updown.go has no path sanitization. This vulnerability is fixed in 2.0.0-beta.3.
CVE-2026-44895	0.0	GitLab MCP Server lets an AI agent talk directly to GitLab. Prior to 0.6.0, the HTTP transport in src/transport.ts ships with no authentication layer at all and a wildcard Access-Control-Allow-Origin: * on every response. The structural defect is that the SSE server stands up a stateful, mutation-capable RPC endpoint that is backed by the operator's GITLAB_PERSONAL_ACCESS_TOKEN without any inbound
CVE-2026-49855	7.5	Tornado is a Python web framework and asynchronous networking library. Prior to 6.5.6, Tornado gzip decompression routines processed limited-size chunks but did not enforce an overall limit on accumulated decompressed chunks, allowing a malicious server accessed by SimpleAsyncHTTPClient or an HTTPServer configured with decompress_request=True to consume effectively unlimited memory. This issue is
CVE-1999-1306	7.5	Cisco IOS 9.1 and earlier does not properly handle extended IP access lists when the IP route cache is enabled and the "established" keyword is set, which could allow attackers to bypass filters.
CVE-1999-1466	7.5	Vulnerability in Cisco routers versions 8.2 through 9.1 allows remote attackers to bypass access control lists when extended IP access lists are used on certain interfaces, the IP route cache is enabled, and the access list uses the "established" keyword.
CVE-1999-1216	7.5	Cisco routers 9.17 and earlier allow remote attackers to bypass security restrictions via certain IP source routed packets that should normally be denied using the "no ip source-route" command.
CVE-1999-0161	7.5	In Cisco IOS 10.3, with the tacacs-ds or tacacs keyword, an extended IP access control list could bypass filtering.
CVE-1999-0511	9.1	IP forwarding is enabled on a machine which is not a router or firewall.
CVE-1999-0525	0.0	IP traceroute is allowed from arbitrary hosts.
CVE-1999-0195	5.0	Denial of service in RPC portmapper allows attackers to register or unregister RPC services or spoof RPC services using a spoofed source IP address such as 127.0.0.1.
CVE-1999-1463	5.0	Windows NT 4.0 before SP3 allows remote attackers to bypass firewall restrictions or cause a denial of service (crash) by sending improperly fragmented IP packets without the first fragment, which the TCP/IP stack incorrectly reassembles into a valid session.

CVE-1999-0667	10.0	The ARP protocol allows any host to spoof ARP replies and poison the ARP cache to conduct IP address spoofing or a denial of service.
CVE-1999-1061	7.5	HP Laserjet printers with JetDirect cards, when configured with TCP/IP, can be configured without a password, which allows remote attackers to connect to the printer and change its IP address or disable logging.
CVE-1999-0762	2.6	When Javascript is embedded within the TITLE tag, Netscape Communicator allows a remote attacker to use the "about" protocol to gain access to browser information.
CVE-2001-1027	10.0	Buffer overflow in WindowMaker (aka wmaker) 0.64 and earlier allows remote attackers to execute arbitrary code via a long window title.
CVE-2001-0955	7.2	Buffer overflow in fbglyph.c in XFree86 before 4.2.0, related to glyph clipping for large origins, allows attackers to cause a denial of service and possibly gain privileges via a large number of characters, possibly through the web page search form of KDE Konqueror or from an xterm command with a long title.
CVE-2002-0217	7.5	Cross-site scripting (CSS) vulnerabilities in the Private Message System for XOOPS 1.0 RC1 allow remote attackers to execute Javascript on other web clients via (1) the Title field or a Private Message Box or (2) the image field parameter in pmlite.php.
CVE-2002-0257	7.5	Cross-site scripting vulnerability in auction.pl of MakeBid Auction Deluxe 3.30 allows remote attackers to obtain information from other users via the form fields (1) TITLE, (2) DESCITIT, (3) DESC, (4) searchstring, (5) ALIAS, (6) EMAIL, (7) ADDRESS1, (8) ADDRESS2, (9) ADDRESS3, (10) PHONE1, (11) PHONE2, (12) PHONE3, or (13) PHONE4.
CVE-2002-0590	7.5	Cross-site scripting (CSS) vulnerability in IcrediBB 1.1 Beta allows remote attackers to execute arbitrary script and steal cookies as other IcrediBB users via the (1) title or (2) body of posts.
CVE-2002-0535	5.0	Cross-site scripting vulnerabilities in PostBoard 2.0.1 and earlier allows remote attackers to execute script as other users via (1) an [IMG] tag when BBCode is enabled, or (2) in a topic title.
CVE-2002-0547	7.5	Buffer overflow in the mini-browser for Winamp 2.79 and earlier allows remote attackers to cause a denial of service (crash) and possibly execute arbitrary code via a long string in the title field of an ID3v2 tag.
CVE-2002-0919	7.5	CGIScript.net csPassword.cgi allows remote authenticated users to modify the .htaccess file and gain privileges via newlines in the title field of the edit page.
CVE-2002-0931	7.5	Cross-site scripting vulnerabilities in MyHelpDesk 20020509, and possibly other versions, allows remote attackers to execute script as other users via a (1) Title or (2) Description when a new ticket is created by a support assistant, via the "id" parameter to the index.php script with the (3) tickettime, (4) ticketfiles, or (5) updateticketlog operations, or (6) via the update section when a tick

Score CVSS moyen : 6.6/10 — Nombre de CVE : 42

■ Recommendations IA

1. [CVE-2022-35252] to deny service to all siblings.
2. [ZAP — Content Security Policy (CSP) Header Not Set] Ensure that your web server, application server, load balancer, etc. is configured to set the Content-Security-Policy header.
3. [ZAP — Sub Resource Integrity Attribute Missing] Provide a valid integrity attribute to the tag.
4. [ZAP — Cookie No HttpOnly Flag] Ensure that the HttpOnly flag is set for all cookies.
5. [ZAP — Cookie with SameSite Attribute None] Ensure that the SameSite attribute is set to either 'lax' or ideally 'strict' for all cookies.
6. [ZAP — Cross-Domain JavaScript Source File Inclusion] Ensure JavaScript source files are loaded from only trusted sources, and the sources can't be controlled by end users of the application.
7. [ZAP — Cross-Origin-Embedder-Policy Header Missing or Invalid] Ensure that the application/web server sets the Cross-Origin-Embedder-Policy header appropriately, and that it sets the Cross-Origin-Embedder-Policy header to

'require-corp' for documents. If possible, ensure that the end user uses a standards-compliant and modern web browser that supports the Cross-Origin-Embedder-Policy header (https://caniuse.com/mdn-http_headers_cross-origin-embedder-policy).

8. [ZAP — Cross-Origin-Opener-Policy Header Missing or Invalid] Ensure that the application/web server sets the Cross-Origin-Opener-Policy header appropriately, and that it sets the Cross-Origin-Opener-Policy header to 'same-origin' for documents. 'same-origin-allow-popups' is considered as less secured and should be avoided. If possible, ensure that the end user uses a standards-compliant and modern web browser that supports the Cross-Origin-Opener-Policy header (https://caniuse.com/mdn-http_headers_cross-origin-opener-policy).

9. [ZAP — Cross-Origin-Resource-Policy Header Missing or Invalid] Ensure that the application/web server sets the Cross-Origin-Resource-Policy header appropriately, and that it sets the Cross-Origin-Resource-Policy header to 'same-origin' for all web pages. 'same-site' is considered as less secured and should be avoided. If resources must be shared, set the header to 'cross-origin'. If possible, ensure that the end user uses a standards-compliant and modern web browser that supports the Cross-Origin-Resource-Policy header (https://caniuse.com/mdn-http_headers_cross-origin-resource-policy).

10. [ZAP — Strict-Transport-Security Header Not Set] Ensure that your web server, application server, load balancer, etc. is configured to enforce Strict-Transport-Security.

11. [ZAP — X-Content-Type-Options Header Missing] Ensure that the application/web server sets the Content-Type header appropriately, and that it sets the X-Content-Type-Options header to 'nosniff' for all web pages. If possible, ensure that the end user uses a standards-compliant and modern web browser that does not perform MIME-sniffing at all, or that can be directed by the web application/web server to not perform MIME-sniffing.

12. [ZAP — Non-Storable Content] The content may be marked as storable by ensuring that the following conditions are satisfied: The request method must be understood by the cache and defined as being cacheable ("GET", "HEAD", and "POST" are currently defined as cacheable) The response status code must be understood by the cache (one of the 1XX, 2XX, 3XX, 4XX, or 5XX response classes are generally understood) The "no-store" cache directive must not appear in the request or response header fields For caching by "shared" caches such as "proxy" caches, the "private" response directive must not appear in the response For caching by "shared" caches such as "proxy" caches, the "Authorization" header field must not appear in the request, unless the response explicitly allows it (using one of the "must-revalidate", "public", or "s-maxage" Cache-Control response directives) In addition to the conditions above, at least one of the following conditions must also be satisfied by the response: It must contain an "Expires" header field It must contain a "max-age" response directive For "shared" caches such as "proxy" caches, it must contain a "s-maxage" response directive It must contain a "Cache Control Extension" that allows it to be cached It must have a status code that is defined as cacheable by default (200, 203, 204, 206, 300, 301, 404, 405, 410, 414, 501).

13. [ZAP — Re-examine Cache-control Directives] For secure content, ensure the cache-control HTTP header is set with "no-cache, no-store, must-revalidate". If an asset should be cached consider setting the directives "public, max-age, immutable".

14. [ZAP — Retrieved from Cache] Validate that the response does not contain sensitive, personal or user-specific information. If it does, consider the use of the following HTTP response headers, to limit, or prevent the content being stored and retrieved from the cache by another user: Cache-Control: no-cache, no-store, must-revalidate, private Pragma: no-cache Expires: 0 This configuration directs both HTTP 1.0 and HTTP 1.1 compliant caching servers to not store the response, and to not retrieve the response (without validation) from the cache, in response to a similar request.

15. [ZAP — Session Management Response Identified] This is an informational alert rather than a vulnerability and so there is nothing to fix.

16. Désactiver TLSv1.0/TLSv1.1 et n'autoriser que TLSv1.2 et TLSv1.3.

17. Retirer les suites de chiffrement faibles (3DES, RC4) au profit d'AES-GCM ou ChaCha20-Poly1305.

■ Plan de correction

Immédiate (P1)	CVE-1999-0667	Appliquer le correctif selon l'avis NVD.
Immédiate (P1)	CVE-2001-1027	Appliquer le correctif selon l'avis NVD.
Immédiate (P1)	CVE-2026-35392	Appliquer le correctif selon l'avis NVD.

Immédiate (P1)	CVE-2019-3888	Appliquer le correctif selon l'avis NVD.
Immédiate (P1)	CVE-2017-7504	Appliquer le correctif selon l'avis NVD.
Immédiate (P1)	CVE-1999-0511	Appliquer le correctif selon l'avis NVD.
Immédiate (P1)	CVE-2004-0867	Appliquer le correctif selon l'avis NVD.
Immédiate (P1)	CVE-2005-2985	Appliquer le correctif selon l'avis NVD.
Immédiate (P1)	CVE-2002-0931	Appliquer le correctif selon l'avis NVD.
Immédiate (P1)	CVE-2016-2183	Appliquer le correctif selon l'avis NVD.
Immédiate (P1)	CVE-2003-1268	Appliquer le correctif selon l'avis NVD.
Immédiate (P1)	CVE-2004-1926	Appliquer le correctif selon l'avis NVD.
Immédiate (P1)	CVE-2004-0866	Appliquer le correctif selon l'avis NVD.
Immédiate (P1)	CVE-2004-0746	Appliquer le correctif selon l'avis NVD.
Immédiate (P1)	CVE-2020-5403	Appliquer le correctif selon l'avis NVD.
Immédiate (P1)	CVE-2026-49855	Appliquer le correctif selon l'avis NVD.
Immédiate (P1)	CVE-1999-1306	Appliquer le correctif selon l'avis NVD.
Immédiate (P1)	CVE-1999-1466	Appliquer le correctif selon l'avis NVD.
Immédiate (P1)	CVE-1999-1216	Appliquer le correctif selon l'avis NVD.
Immédiate (P1)	CVE-1999-0161	Appliquer le correctif selon l'avis NVD.
Immédiate (P1)	CVE-1999-1061	Appliquer le correctif selon l'avis NVD.
Immédiate (P1)	CVE-2002-0217	Appliquer le correctif selon l'avis NVD.
Immédiate (P1)	CVE-2002-0257	Appliquer le correctif selon l'avis NVD.
Immédiate (P1)	CVE-2002-0590	Appliquer le correctif selon l'avis NVD.
Immédiate (P1)	CVE-2002-0547	Appliquer le correctif selon l'avis NVD.
Immédiate (P1)	CVE-2002-0919	Appliquer le correctif selon l'avis NVD.
Immédiate (P1)	CVE-2014-3566	Appliquer le correctif selon l'avis NVD.
Immédiate (P1)	CVE-2001-0955	Appliquer le correctif selon l'avis NVD.
Court terme (P2)	CVE-2007-1939	Appliquer le correctif selon l'avis NVD.
Court terme (P2)	CVE-2018-12537	Appliquer le correctif selon l'avis NVD.

■ Conclusion

L'audit du domaine google.com révèle un niveau de risque critique. Des actions correctives immédiates sont nécessaires pour réduire l'exposition (score sécurité 1.4/10). Priorisez les CVE à CVSS élevé et les alertes ZAP à risque High.

Document généré automatiquement par CyberScan le 17/07/2026 à 16:16 UTC. Usage strictement confidentiel.